TÀI LIỆU ÔN BẢO VỆ

NGUYỄN CAO HOÀNG

THỰC ĐƠN – NHÂN VIÊN – ĐĂNG NHẬP / BẢO MẬT

Dự án quản lý nhà hàng hải sản • Nhóm 4

Đối chiếu bảng phân công và mã nguồn ngày 10/11/2026

Học theo luồng xử lý; tự chỉ được vị trí trong code.

Ưu tiên: xem danh sách → thêm/sửa → chặn xóa → đăng nhập.

Phạm vi	**Nội dung**
Tài liệu này	Hướng dẫn học, câu hỏi và demo cho Hoàng.
Báo cáo nhóm	Xem BTL.docx để trình bày nội dung chính thức.

1. Phần của Hoàng và những điều phải nói đúng

Bạn phụ trách thực đơn, nhân viên và đăng nhập/bảo mật. Ba bảng nghiệp vụ chính là LOAI_MON, MON_AN, NHAN_VIEN. Mã hiện tại dùng thêm TAI_KHOAN để đăng ký và đăng nhập.

Loại món: danh sách, thêm, sửa, xóa, tra cứu, đếm số món theo loại. Không xóa loại còn món.

Món ăn: tên, loại, đơn vị, giá, URL ảnh, mô tả, trạng thái; tìm kiếm và lọc; xem dạng thẻ/bảng; tổng hợp lượng đã bán. Không xóa món đã nằm trong hóa đơn.

Nhân viên: hồ sơ, liên hệ, chức vụ, ca làm, lương, ngày vào làm, trạng thái. Không xóa nhân viên đã lập hóa đơn hoặc phiếu nhập. Đây chưa phải chức năng chấm công/tính lương tự động.

Bảo mật: đăng ký, đăng nhập, đăng xuất, băm BCrypt, yêu cầu đăng nhập khi vào trang nghiệp vụ và bảo vệ CSRF. Chưa chia quyền chức năng theo vai trò quản lý/thu ngân/phục vụ. Chức vụ nhân viên không tự tạo quyền tài khoản.

Phần khách hàng/đặt bàn thuộc Đức, hóa đơn/báo cáo thuộc Chiến, kho/nhập hàng thuộc Đạt. Bạn cần hiểu các điểm tích hợp với phần mình, không cần nhận toàn bộ nghiệp vụ đó là phần đã làm của mình.

2. Bảy việc nên nắm trước khi báo cáo

1. Nói được phần mình làm, dữ liệu đầu vào và kết quả của từng chức năng.

2. Giải thích được Controller, Service, Repository, Entity và DTO khác nhau thế nào.

3. Tự lần được một luồng xem danh sách từ URL đến database rồi ra HTML.

4. Tự lần được một luồng thêm/sửa từ form POST đến lưu database.

5. Nhớ ba quy tắc chặn xóa và các kiểm tra giá, tên, email.

6. Phân biệt đăng nhập với phân quyền, tài khoản web với user Oracle.

7. Tự demo và nói đúng phạm vi kiểm thử, hạn chế hiện tại.

Thứ tự đọc nếu ít thời gian: LoaiMonController.java → LoaiMonService.java → LoaiMonRepository.java → LoaiMonForm.java → templates/loaimon/index.html. Sau khi hiểu trọn luồng loại món, chuyển sang MonAnService.java, NhanVienService.java và SecurityConfig.java.

Các file Java nằm trong src/main/java/com/QuanLyNHHS/. Giao diện nằm trong src/main/resources/templates/. Bạn có thể dùng Ctrl+P trong VS Code rồi gõ tên file để mở nhanh.

3. Vì sao danh sách món xuất hiện trên màn hình?

Luồng: trình duyệt gửi GET /mon-an → MonAnController.index() → MonAnService.findAll() → MonAnRepository.findAll() → đọc database → Controller đưa danh sách vào Model → Thymeleaf tạo HTML.

Trong MonAnService:

```
public List<MonAn> findAll() {
   return repository.findAll();
}
```

List<MonAn> là danh sách các đối tượng món ăn. findAll() ở đây là hàm service; bên trong nó gọi hàm repository cùng tên.

Trong MonAnController.index(), trích các dòng chính:

```
var dishes = service.findAll();
model.addAttribute("dishes", dishes);
return "monan/index";
```

service.findAll() trả dữ liệu. addAttribute đặt tên dữ liệu để giao diện đọc. return chọn file templates/monan/index.html; không phải câu lệnh SQL.

Trong template:

```
<div class="dish-card" th:each="dish : ${dishes}">
   <!-- Nội dung của từng món -->
</div>
```

dishes là tên thuộc tính trong Model. dish là từng món ở mỗi lần lặp. Nếu có 5 món, Thymeleaf tạo 5 thẻ div. Vòng lặp chạy ở server, trình duyệt nhận HTML đã được dựng.

Cách trả lời ngắn: “Controller lấy danh sách qua Service và Repository, đưa vào Model tên dishes. Thymeleaf dùng th:each duyệt từng món để tạo HTML.”

4. Đoạn select danh sách món bạn vừa hỏi

Trong màn hình hóa đơn, Controller dùng tên danhSachMonAn, khác với dishes của trang quản lý món. Đây là hai tên dữ liệu trong hai luồng khác nhau.

```
model.addAttribute("danhSachMonAn",
   monAnRepository.findAll(Sort.by("tenMon").ascending()));
```

Đoạn HTML rút gọn để dễ hiểu:

```
<select id="monAnSelect">
   <option value="">-- Chọn món ăn --</option>
   <option th:each="mon : ${danhSachMonAn}"
         th:value="${mon.maMon}"
         th:text="${mon.tenMon}">
   </option>
</select>
```

select tạo ô xổ xuống. option tạo một lựa chọn. th:each lặp qua danh sách để tạo nhiều option. danhSachMonAn là biến dữ liệu, không phải tên hàm. mon là biến tạm đại diện từng món. th:value đặt mã món; th:text đặt nội dung nhìn thấy.

Ví dụ sau khi server xử lý, HTML có thể thành:

```
<option value="1">Tôm hấp</option>
<option value="2">Cua rang</option>
```

Chọn Cua rang thì giá trị của ô chọn là chuỗi "2". JavaScript đọc bằng document.getElementById("monAnSelect").value. Phần #numbers.formatDecimal trong file thật chỉ định dạng giá để hiển thị; không truy vấn database và không làm thay đổi giá được lưu.

Với JavaBean, ${mon.tenMon} đọc thuộc tính tenMon thông qua getter tương ứng. Dữ liệu phải được Controller truyền đúng tên thì biểu thức giao diện mới đọc được danh sách mong muốn.

5. Thymeleaf: những thuộc tính dễ được hỏi

Cú pháp	Cách hiểu
th:each	Lặp qua danh sách, tạo thẻ cho từng phần tử.
th:text	Gán nội dung chữ vào thẻ; escape ký tự HTML trong dữ liệu.
th:value	Gán giá trị cho input hoặc option.
th:object="${form}"	Chọn đối tượng dữ liệu của biểu mẫu.
th:field="*{tenMon}"	Liên kết trường nhập với thuộc tính tenMon của đối tượng form.
th:action	Xác định URL nhận khi gửi biểu mẫu.
th:if	Chỉ hiển thị khi điều kiện đúng.
${...}	Đọc biến/thuộc tính trong ngữ cảnh dữ liệu.
*{...}	Đọc thuộc tính của đối tượng đang được th:object chọn.
@{...}	Tạo URL phù hợp ngữ cảnh ứng dụng.

id="monAnSelect" dùng để nhận diện phần tử trong JavaScript/CSS. id không tự quyết định tên tham số gửi lên server; các control gửi form cần name phù hợp hoặc dùng cơ chế th:field tạo liên kết đó.

GET thường dùng để đọc hoặc mở form. POST được dùng cho thêm, sửa, xóa trong ba module của bạn. Nút xóa không nên chỉ được giải thích là “ẩn dòng”; thao tác xóa thật gửi POST và được kiểm tra ở Service.

6. Luồng thêm và sửa: học thật chắc một ví dụ

Ví dụ thêm loại "Món hấp":

1. GET /loai-mon/them: Controller tạo LoaiMonForm rỗng và mở form.

2. Người dùng nhập dữ liệu, gửi POST /loai-mon/them.

3. @ModelAttribute gán dữ liệu vào form; @Valid kiểm tra các điều kiện trên DTO. BindingResult giữ lỗi.

4. Nếu không có lỗi, Controller gọi service.save(null, form).

5. Service tạo LoaiMon mới, gán tên/mô tả/trạng thái rồi gọi repository.saveAndFlush(entity).

6. Entity dùng SEQ_LOAI_MON để sinh mã; giao dịch hoàn tất. Controller chuyển về danh sách và hiện thông báo thành công.

Đoạn cốt lõi từ LoaiMonService:

```
LoaiMon entity = id == null ? new LoaiMon() : getById(id);
entity.setTenLoai(form.getTenLoai());
entity.setMoTa(form.getMoTa());
entity.setTrangThai(form.getTrangThai());
return repository.saveAndFlush(entity);
```

Khi sửa /loai-mon/sua/5, id bằng 5 lấy từ URL. GET sửa đưa dữ liệu cũ vào form; POST sửa cập nhật đúng bản ghi. getById(5) báo lỗi nếu bản ghi không tồn tại, không tự tạo bản ghi mới.

Nếu dữ liệu sai, Controller trả lại form và thông báo, không lưu dữ liệu sai. Khi thành công dùng redirect để tải lại danh sách, tránh việc bấm tải lại trang ngay sau POST lặp thao tác gửi form.

DTO khác Entity: DTO chứa dữ liệu được phép nhập; Entity ánh xạ bản ghi database. Khóa chính được xác định từ URL và logic thêm/sửa, không tùy ý nhận từ nội dung form. WebDataBinder.setAllowedFields giới hạn các trường được gán.

7. Xóa, kiểm tra dữ liệu và giao dịch

Ba câu phải nhớ:

1. Không xóa loại món còn món, vì món đang tham chiếu loại đó.

2. Không xóa món đã có trong bất kỳ hóa đơn nào, vì cần giữ lịch sử chứng từ.

3. Không xóa nhân viên đã lập hóa đơn hoặc phiếu nhập, vì cần giữ thông tin người lập.

Món đã được dùng có thể chuyển Tạm hết; nhân viên nghỉ có thể chuyển Đã nghỉ việc. Kiểm tra ở Service đưa thông báo nghiệp vụ dễ hiểu; khóa ngoại ở database vẫn là lớp bảo vệ cần thiết.

Ví dụ từ MonAnService.delete():

```
if (ctHoaDonRepository.existsById_MaMon(id)) {
   throw new IllegalArgumentException(
      "Món đã có trong hóa đơn, không thể xóa. Bạn có thể đổi trạng thái thành Tạm hết.");
}
```

@NotBlank kiểm tra chuỗi không null, không rỗng hoặc chỉ khoảng trắng. @NotNull cấm null. @Size giới hạn độ dài. @DecimalMin kiểm tra giá trị tối thiểu. @Digits giới hạn chữ số. @Email kiểm tra định dạng email. Các annotation được kích hoạt trong luồng form qua @Valid.

@Transactional tổ chức thao tác trong một giao dịch: commit khi thành công; rollback khi gặp loại lỗi phù hợp. @Transactional(readOnly = true) mô tả giao dịch đọc; các hàm ghi có annotation riêng. flush gửi lệnh đang chờ xuống database; flush chưa phải commit.

8. Java và Spring: giải thích bằng lời đơn giản

Thành phần	Câu trả lời ngắn
Class	Bản mô tả đối tượng, gồm dữ liệu và phương thức.
Object / entity	Một đối tượng cụ thể, ví dụ món Tôm hấp.
private	Chỉ truy cập trực tiếp trong lớp.
public	Cho phép gọi từ bên ngoài theo phạm vi lớp.
final repository	Biến tham chiếu không được gán lại sau khi khởi tạo.
Constructor	Hàm khởi tạo nhận các đối tượng phụ thuộc. Spring truyền chúng vào.
this.repository = repository	Gán tham số repository cho thuộc tính của đối tượng hiện tại.
Getter / setter	Hàm đọc và hàm gán thuộc tính.
List<MonAn>	Danh sách các đối tượng MonAn.
Map<Long, Long>	Bảng tra theo khóa, ví dụ mã loại → số món.
id == null ? A : B	Nếu id null chọn A, ngược lại chọn B.
return	Trả kết quả cho nơi đã gọi hàm.
throw	Phát sinh lỗi để luồng gọi xử lý.
@Controller	Đăng ký lớp nhận yêu cầu web.
@Service	Đăng ký lớp xử lý nghiệp vụ.
@GetMapping / @PostMapping	Ánh xạ URL và phương thức HTTP vào hàm.
@PathVariable	Lấy dữ liệu từ đoạn URL, ví dụ mã 5.

MonAnRepository extends JpaRepository<MonAn, Long> nghĩa là repository quản lý entity MonAn, khóa chính Long. Spring Data cung cấp triển khai cho findAll, findById, save, delete... nên không cần tự viết SQL cho từng thao tác cơ bản.

@Entity đánh dấu lớp ánh xạ dữ liệu; @Table đặt tên bảng; @Id đánh dấu khóa chính; @Column đặt cột; @GeneratedValue và @SequenceGenerator cấu hình sinh mã. @ManyToOne diễn tả nhiều món cùng thuộc một loại.

9. Database và các truy vấn của phần mình

LOAI_MON.MA_LOAI là khóa chính của loại. MON_AN.MA_MON là khóa chính của món; MON_AN.MA_LOAI tham chiếu loại. Đây là quan hệ một loại có nhiều món. NHAN_VIEN.MA_NV được hóa đơn và phiếu nhập dùng để nhận diện người lập.

Giá/lương dùng BigDecimal vì cần biểu diễn và tính số thập phân phù hợp với tiền. NUMBER(12,2) chứa tổng 12 chữ số, trong đó 2 số sau dấu thập phân; phần nguyên tối đa 10 chữ số. Định dạng tiền trên HTML không thay thế kiểm tra giá trị ở server.

Đếm số món theo loại, trích MonAnRepository:

```
SELECT m.loaiMon.maLoai, COUNT(m)
FROM MonAn m
GROUP BY m.loaiMon.maLoai
```

Đây là JPQL, dùng tên entity và thuộc tính Java. COUNT đếm số món; GROUP BY gom theo mã loại. LoaiMonService đổi kết quả thành Map<mã loại, số món> để giao diện tra cứu.

Lượng đã bán dùng SUM(c.soLuong), nối CTHoaDon với HoaDon, lọc trạng thái Da thanh toan và GROUP BY mã món. Chỉ hóa đơn đã thanh toán được tính vào lượng đã bán. Hóa đơn chưa thanh toán vẫn là dữ liệu liên quan để chặn xóa món.

Sửa giá món trong MonAnService không tự sửa giá ở chi tiết hóa đơn cũ. Nếu cô hỏi về nghiệp vụ sửa toàn bộ hóa đơn, đó là một luồng riêng trong HoaDonService; không suy từ hàm sửa món sang mọi thao tác hóa đơn.

10. Đăng nhập và bảo mật: phần dễ bị hỏi sâu

Đăng nhập trả lời "bạn là ai"; phân quyền trả lời "bạn được làm gì". Website hiện đã yêu cầu đăng nhập vào các trang nghiệp vụ nhưng chưa chia quyền CRUD theo từng vai trò.

Luồng đăng nhập: người dùng gửi form /login → bộ lọc Spring Security nhận tên/mật khẩu → TaiKhoanService.loadUserByUsername() lấy tài khoản → PasswordEncoder đối chiếu mật khẩu với chuỗi BCrypt → tạo phiên đăng nhập khi hợp lệ → chuyển về trang chủ.

Luồng đăng ký: nhận DangKyForm → kiểm tra dữ liệu, tên trùng và xác nhận mật khẩu → băm bằng passwordEncoder.encode(...) → lưu TAI_KHOAN. Khi đăng nhập dùng matches(...); không giải mã mật khẩu để so sánh.

SecurityConfig cho /login, /register và tài nguyên CSS/JS/ảnh truy cập công khai; anyRequest().authenticated() yêu cầu các URL còn lại đã đăng nhập. Mọi tài khoản hiện được cấp ROLE_USER. Đổi chức vụ nhân viên không thay đổi quyền này.

CSRF là giả mạo yêu cầu từ trang khác dựa vào phiên đăng nhập của người dùng. Token CSRF giúp server kiểm tra các yêu cầu thay đổi dữ liệu. Trong bộ test, POST thiếu token bị từ chối. CSRF không thay thế kiểm tra đăng nhập, phân quyền hoặc validation.

NHHS_APP là user kết nối Oracle; tài khoản ở TAI_KHOAN là tài khoản website. Role/privilege Oracle và role Spring Security thuộc hai lớp khác nhau. File oracle_setup_user.sql có GRANT không chứng minh website đã phân quyền URL hoặc script đã chạy trên database.

11. Những câu cô có thể hỏi và câu trả lời ngắn

1. Em phụ trách phần nào?

"Em phụ trách loại món, món ăn, nhân viên và đăng nhập/bảo mật. Ba bảng chính là LOAI_MON, MON_AN, NHAN_VIEN; tài khoản hiện lưu thêm ở TAI_KHOAN."

2. Dữ liệu danh sách món lấy ở đâu?

"Repository đọc database qua JPA; Service trả danh sách; Controller đưa vào Model; Thymeleaf lặp để tạo HTML."

3. th:each có gọi hàm không?

"Trong đoạn này không gọi hàm. Nó lấy danh sách đã truyền vào Model và duyệt từng phần tử."

4. Model ở Controller có phải bảng database không?

"Không. org.springframework.ui.Model là nơi mang dữ liệu sang view. Entity trong package model mới là lớp ánh xạ dữ liệu."

5. Vì sao tách Service?

"Để tách quy tắc nghiệp vụ và giao dịch khỏi việc nhận HTTP và chọn giao diện."

6. Vì sao cần DTO?

"Để nhận đúng các trường cho phép và kiểm tra dữ liệu trước khi cập nhật entity."

7. Vì sao Repository ít code mà vẫn đọc ghi được?

"Vì kế thừa JpaRepository, Spring Data cung cấp triển khai cho các hàm cơ bản."

8. Thêm và sửa khác nhau ở đâu?

"Thêm truyền id null để tạo entity; sửa lấy entity theo mã URL rồi cập nhật. Mã không có thì báo lỗi."

9. Xóa loại đang có món thì sao?

"Service kiểm tra quan hệ và chặn xóa, yêu cầu xử lý các món trước."

10. Tìm kiếm có query Oracle mỗi lần gõ không?

"Ở ba màn hình này, JavaScript lọc các phần tử đã tải lên trang. Khi cần dữ liệu lớn nên bổ sung tìm kiếm và phân trang ở server."

11. Vì sao lưu giá trong chi tiết hóa đơn?

"Để giữ giá giao dịch khi giá danh mục thay đổi."

12. Có phân quyền quản lý và phục vụ chưa?

"Hiện có kiểm soát đăng nhập chung, chưa chia quyền chức năng theo các vai trò đó."

13. BCrypt có giải mã được không?

"Đây là băm mật khẩu; khi đăng nhập dùng bộ mã hóa để đối chiếu, không giải mã lấy mật khẩu gốc."

14. Đổi chức vụ thành quản lý có thêm quyền không?

"Chưa. Chức vụ là dữ liệu hồ sơ; tài khoản hiện chưa liên kết với nhân viên."

15. Đã kiểm thử những gì?

"Lần rà soát ngày 10/11/2026 đã chạy đạt 14 kiểm thử Java bằng H2/MockMvc và 4 kiểm thử JavaScript. Chưa coi đó là kết quả kiểm thử đầy đủ trên Oracle."

16. Run rồi sao chưa hiện web?

"Cần chờ ứng dụng khởi động thành công và xem Console. Chỉ khi ApplicationReadyEvent xảy ra mới tự mở trình duyệt. Cần kiểm tra kết nối database và cổng HTTP có bị chiếm không."

12. Kịch bản demo và bài nói mẫu

Chuẩn bị tài khoản và dữ liệu demo riêng. Xác nhận ứng dụng chạy trên đúng cổng và kết nối Oracle trước buổi báo cáo. Không xóa dữ liệu thật để minh họa.

1. Mở trang nghiệp vụ khi chưa đăng nhập để thấy yêu cầu đăng nhập.

2. Đăng nhập; mở loại món và thêm “Loại demo Hoàng”.

3. Thêm món vào loại đó; mở sửa, thay giá hoặc trạng thái.

4. Tìm theo tên, lọc loại, chuyển thẻ/bảng. Tải lại để kiểm tra dữ liệu đã lưu.

5. Thử xóa loại đang chứa món: giải thích vì sao bị chặn.

6. Thêm nhân viên demo, sửa trạng thái; giải thích vì sao hồ sơ đã lập chứng từ không thể xóa.

7. Xóa dữ liệu demo chưa liên quan theo đúng thứ tự; đăng xuất.

Bài nói mẫu khoảng hai phút:

“Em là Nguyễn Cao Hoàng, phụ trách thực đơn, nhân viên và đăng nhập/bảo mật. Với thực đơn, người dùng quản lý loại món và món ăn, có tìm kiếm, lọc và hai cách xem. Với nhân viên, hệ thống quản lý hồ sơ, chức vụ, ca làm, lương và trạng thái.

Phần em đi theo các tầng Controller, Service, Repository và Entity. Ví dụ xem món: Controller nhận GET /mon-an, gọi Service lấy dữ liệu qua Repository, đưa vào Model tên dishes; Thymeleaf dùng th:each tạo danh sách HTML. Khi lưu, DTO kiểm tra dữ liệu rồi Service kiểm tra nghiệp vụ và ghi trong giao dịch.

Các quy tắc chính là không xóa loại còn món, món đã có hóa đơn và nhân viên đã lập chứng từ. Phần bảo mật dùng Spring Security và BCrypt, có đăng nhập, đăng xuất và CSRF. Phân quyền chi tiết theo vai trò hiện chưa cài đặt.

Phần này đã chạy đạt 14 kiểm thử Java trên H2 và 4 kiểm thử JavaScript trong lần rà soát. Em vẫn cần kiểm tra luồng demo trên Oracle trước khi báo cáo.”

Khi chưa nhớ câu trả lời, hãy nói: “Em xin mở đúng hàm để giải thích theo luồng xử lý.” Sau đó chỉ vào Controller → Service → Repository → template. Nói theo code đang có, không đoán rằng một chức năng đã hoàn thành chỉ vì có tên nút hoặc tên file.